

SIMATS ENGINEERING ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking COURSE CODE: ITA1410

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01 Total Marks:100

Annexure A VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

*I G NITHYA SREE (192424103) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: G NITHYA SREE

S.No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
.						

1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	

5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

Annexure A

1. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user security awareness.

• Case Study

Firesheep demonstrated that an attacker connected to the same open wireless

network could potentially capture unencrypted session cookies and use them to impersonate an authenticated user. The incident highlighted weaknesses in open Wi-Fi, HTTP communication, insecure cookies, and inadequate session protection.

- **Objective**

To assess the security risks associated with public Wi-Fi networks and determine whether insecure communication and session-management practices could expose user information.

- **Vulnerabilities Identified**

Vulnerability	Severity
Open wireless network	High
Unencrypted HTTP traffic	Critical
Insecure session cookies	Critical

Lack of HSTS	High
Lack of client isolation	High
Poor user awareness	Medium

- **Impact**

An attacker could potentially:

- Monitor unencrypted network traffic.
- Obtain sensitive information transmitted without encryption.
- Attempt session hijacking where applications use insecure cookies.
- Impersonate users whose sessions are inadequately protected.
- Gain access to sensitive accounts or information.

- **Recommended Countermeasures**

- Enforce **HTTPS** throughout the entire website.
- Enable **HSTS**.

- Configure cookies with Secure and HttpOnly attributes. •

Use appropriate SameSite cookie settings.

- Implement wireless client isolation.
- Encourage VPN use on untrusted networks.
- Educate users about public Wi-Fi risks.

• Kali Linux Implementation Commands

- **Identify wireless interface:** `iwconfig/ ip link`
- **View nearby wireless networks:** `sudo iw dev wlan0 scan` •

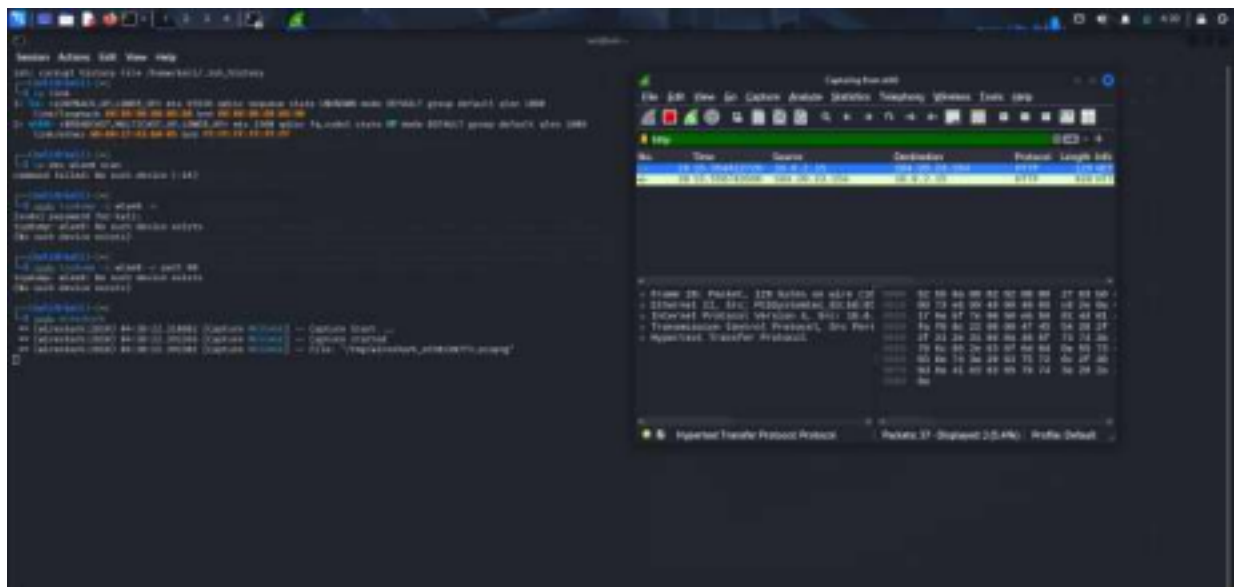
Monitor traffic in your authorized lab: `sudo tcpdump -i wlan0` •

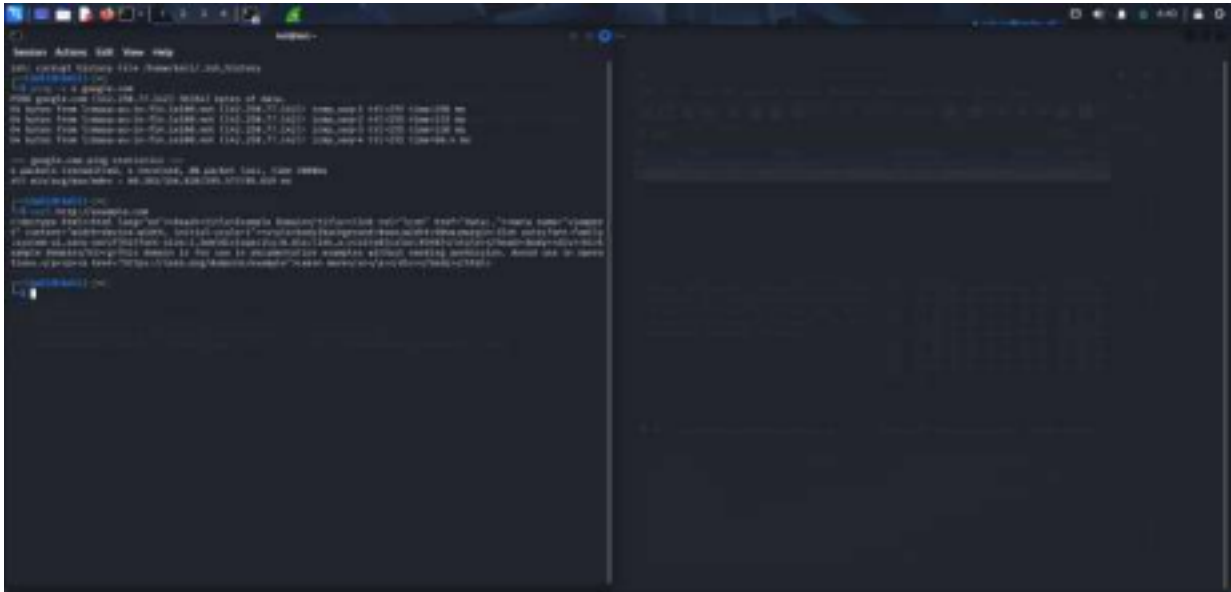
For a specific protocol:

- `sudo tcpdump -i wlan0 -n port 80`
- **Analyze traffic using Wireshark:** `sudo wireshark`

• Expected Result

You should demonstrate that **HTTP traffic is readable**, whereas properly configured HTTPS traffic is encrypted.





2. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable use policies, and legal consequences.

• Case Study

The Marriott incident involved the use of Wi-Fi equipment to send deauthentication messages that disconnected guests from their wireless networks. The incident highlighted weaknesses in the protection of IEEE 802.11 management frames.

• Objective

To assess the availability risks associated with unprotected Wi-Fi management frames and identify controls that can prevent unauthorized deauthentication.

• Vulnerabilities Identified

Vulnerability	Severity
Unprotected management frames	High
Deauthentication abuse	High

Lack of wireless monitoring	High
Lack of Protected Management Frames	High
Weak wireless security configuration	Medium

• Impact

Deauthentication attacks can cause:

- Wireless service disruption.
- Loss of network availability.
- Repeated client disconnections.
- User inconvenience.
- Potential disruption of business services.

• Recommended Countermeasures

- Enable **Protected Management Frames (PMF)**.
- Use WPA3 where supported.
- Deploy WIDS/WIPS.
- Monitor unusual management-frame activity.
- Establish wireless acceptable-use policies.
- Maintain incident-response procedures.

• Kali Linux Implementation Commands

For a safe lab demonstration, focus on **detecting and analyzing management frames**, rather than disrupting third-party networks.

Step 1

```
iwconfig
```

Step 2

```
sudo airmon-ng start wlan0
```

Step 3

```
sudo airodump-ng wlan0mon
```

Step 4 – Capture traffic for analysis

`sudo airodump-ng --write wifi_capture wlan0mon`

Step 5 – Analyze the capture

`sudo wireshark wifi_capture-01.cap`

In Wireshark, you can filter management frames using:

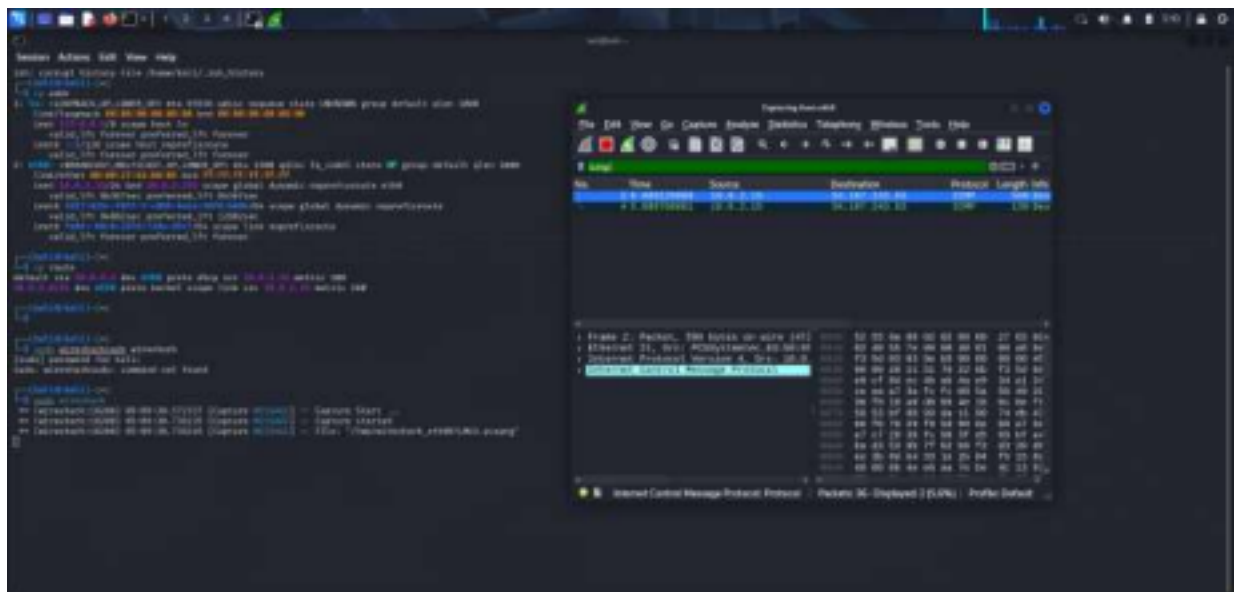
`wlan.fc.type == 0`

For deauthentication frames:

`wlan.fc.type_subtype == 0x0c`

• Expected Result

The capture can be examined for management-frame activity and suspicious deauthentication patterns.



3. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

• Case Study

A security experiment during the 2016 Republican National Convention demonstrated that users could connect to fake open Wi-Fi networks. The experiment showed that users often trust familiar SSID names without verifying whether the network is legitimate.

• Objective

To assess the risks associated with fake access points and determine how users and organizations can detect and prevent evil-twin attacks.

• Vulnerabilities Identified

Vulnerability	Severity
Open Wi-Fi	High
SSID impersonation	High
Evil-twin access point	Critical
Automatic Wi-Fi connection	High
Weak captive portal security	High
Lack of rogue AP detection	High

• Impact

A fake access point could potentially:

- Trick users into connecting to an attacker-controlled network. •

Expose unencrypted traffic.

- Redirect users to fraudulent websites.
- Collect information entered into an insecure captive portal.
- Facilitate further attacks against connected devices.

• **Recommended Countermeasures**

- Deploy **Wireless Intrusion Detection/Prevention Systems (WIDS/WIPS)**. •

Use enterprise Wi-Fi authentication such as **802.1X**.

- Disable automatic connection to unknown networks.
- Use HTTPS for captive portals.
- Educate users to verify official SSIDs.
- Use VPNs when accessing sensitive resources.

• **Kali Linux Implementation Commands**

Step 1 – Identify wireless interface

```
iwconfig
```

Step 2 – Check wireless interface

```
ip link show
```

Step 3 – Scan your authorized lab environment

```
sudo airodump-ng wlan0
```

Step 4 – Put the interface into monitor mode

```
sudo airmon-ng start wlan0
```

Then:

```
sudo airodump-ng wlan0mon
```

Step 5 – Observe access points

You can examine:

- SSID
- BSSID
- Channel

- Encryption type
- Number of connected clients

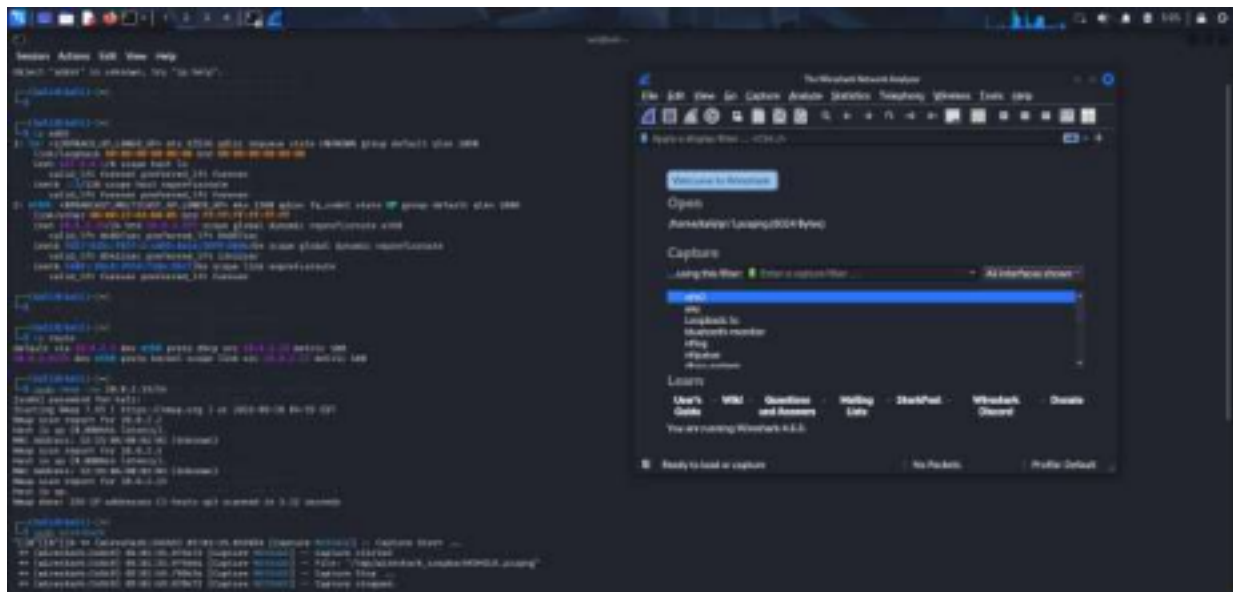
Step 6 – Return to normal mode

`sudo airmon-ng stop wlan0mon`

• Expected Result

You should be able to identify nearby/authorized lab access points and compare their: **SSID + BSSID + channel + encryption**

This demonstrates why simply trusting an SSID is not sufficient.



4. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue access-point detection, staff response procedures, and user-verification methods.

• Case Study

In 2024, Australian authorities charged an individual who allegedly created fake Wi-Fi access points that imitated legitimate networks at airports and other locations. The

case demonstrated the risk of evil-twin attacks in environments where many users depend on public Wi-Fi.

- **Objective**

To assess the vulnerability of public Wi-Fi users to fake access points and identify technical and user-awareness controls.

- **Vulnerabilities Identified**

Vulnerability	Severity
SSID impersonation	High
Fake access point	Critical
Automatic Wi-Fi connection	High
Fake captive portal	Critical
Insufficient rogue AP detection	High
Poor user awareness	Medium

- **Impact**

Potential impacts include:

- Exposure of personal information.
- Credential theft through fraudulent portals. •

Traffic interception.

- Phishing.
- Malware delivery.
- Privacy violations.

- **Recommended Countermeasures**

- Deploy rogue-access-point detection. •

Clearly publish official SSIDs.

- Use secure authentication.
- Use HTTPS for captive portals.

- Disable automatic Wi-Fi connections. •

Encourage VPN usage.

- Train staff to identify rogue access points. •

Educate passengers/users.

• **Kali Linux Implementation Commands**

Step 1 – Identify interface

```
iwconfig
```

Step 2 – Scan authorized wireless

```
environment sudo airodump-ng wlan0
```

Step 3 – Monitor networks

```
sudo airmon-ng start wlan0  
sudo airodump-ng wlan0mon
```

Step 4 – Capture wireless information

```
sudo airodump-ng --write airport_wifi wlan0mon
```

Step 5 – Analyze the capture

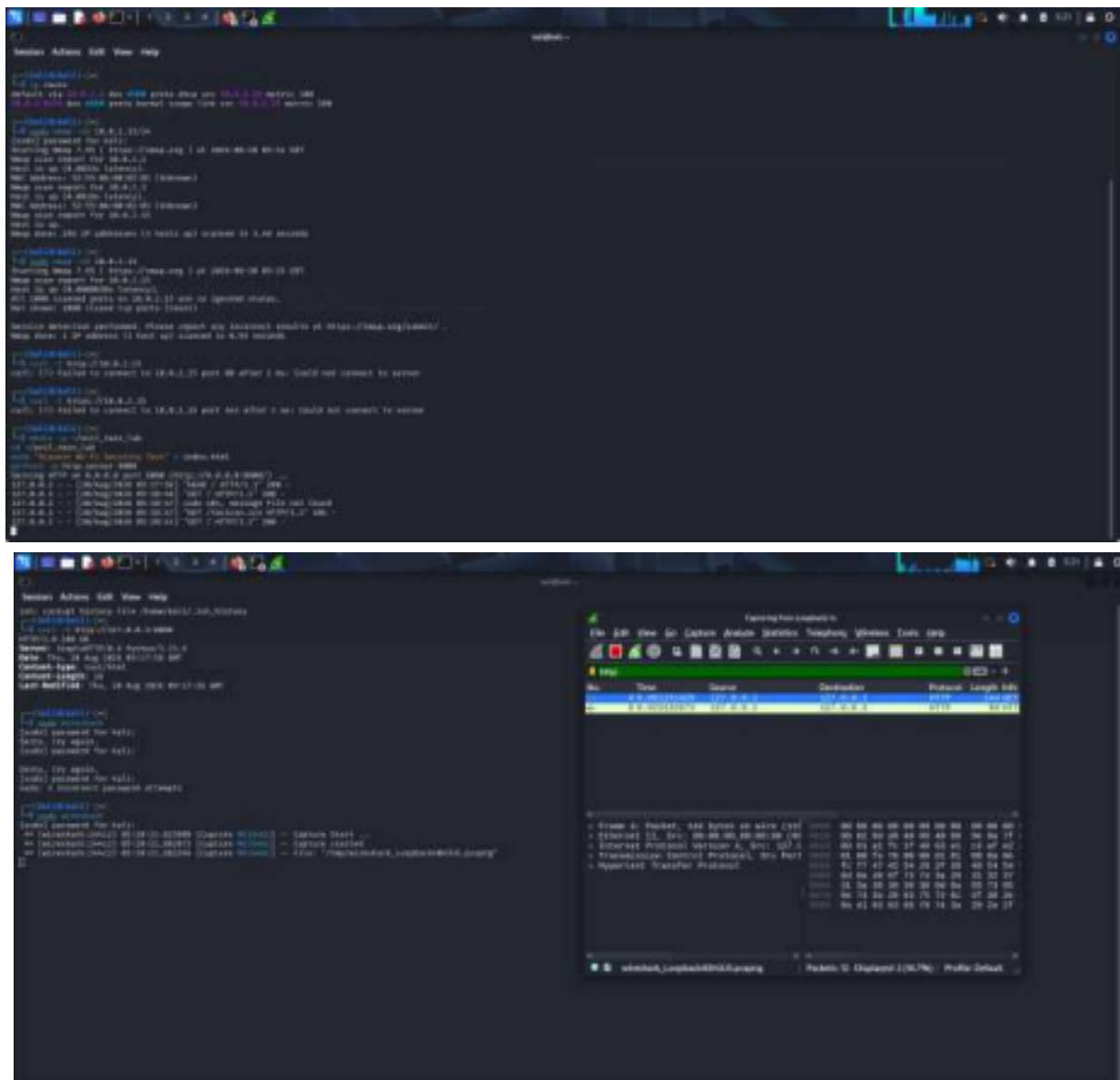
```
sudo wireshark airport_wifi-01.cap
```

Compare:

- SSID
- BSSID
- Channel
- Encryption
- Signal strength

• **Expected Result**

You can demonstrate how wireless monitoring can identify suspicious or duplicate SSIDs in an authorized test environment.



5. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

• Case Study

In September 2024, public Wi-Fi services at 19 major UK railway stations displayed unauthorized offensive content. Reports indicated that the Wi-Fi landing page had

been changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

- **Objective**

To assess weaknesses in administrator authentication, privileged access management, captive-portal security, logging, and third-party access.

- **Vulnerabilities Identified**

Vulnerability	Severity
Compromised administrator account	Critical
Insufficient MFA	Critical
Excessive privileges	High
Weak third-party access control	High
Insufficient logging	High
Poor change management	High
Inadequate account monitoring	High

- **Impact**

Potential impacts include:

- Unauthorized modification of the Wi-Fi portal.
- Distribution of malicious or inappropriate content. •
- Loss of public trust.
- Service disruption.
- Compromise of administrator privileges.
- Reputational damage.

- **Recommended Countermeasures**

- Implement **Multi-Factor Authentication (MFA)**. •
- Use **Privileged Access Management (PAM)**.
- Apply least-privilege access.

- Monitor administrator login activity.
- Maintain detailed audit logs.
- Implement change-approval procedures.
- Restrict third-party access.
- Conduct regular account reviews.
- Maintain incident-response procedures.

• **Kali Linux Implementation Commands**

This case is more about **web/application and account security** than wireless attacks. **Step 1 – Network discovery in your lab**

`ip addr`

`ip route`

Step 2 – Scan your own test server

`nmap -sV <LAB-IP>`

Step 3 – Identify web services

`nmap -p 80,443 -sV <LAB-IP>`

Step 4 – Check HTTP headers

`curl -I http://<LAB-IP>`

For HTTPS:

`curl -I https://<LAB-IP>`

Step 5 – Analyze logs

On a Linux test server:

`sudo tail -f /var/log/auth.log`

You can examine:

- Successful logins
- Failed logins
- Suspicious login attempts

- Administrative activity
- **Expected Result**

The assessment demonstrates the importance of MFA, privileged access management, logging, account monitoring, and secure change management.

Screenshots:

```

kali@kali: ~/network-rail-lab
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~|
$ cd ~/network-rail-lab/captive-portal
(kali@kali)~/network-rail-lab/captive-portal|
$ nano login.html
(kali@kali)~/network-rail-lab/captive-portal|
$ sudo apt update
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [34.8 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:7 http://kali.download/kali kali-rolling/contrib amd64 Packages [114 kB]
Get:8 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [265 kB]
Get:9 http://kali.download/kali kali-rolling/non-free amd64 Packages [183 kB]
Fetched 75.3 MB in 1min 37s (780 kB/s)
2212 packages can be upgraded. Run 'apt list --upgradable' to see them.
(kali@kali)~/network-rail-lab/captive-portal|
$ sudo apt install python3-flask -y
Upgrading:
  mitmproxy  python3-flask
Summary:
  Upgrading: 2, Installing: 0, Removing: 0, Not Upgrading: 2210
  Download size: 1,435 kB
  Space needed: 476 kB / 62.5 GB available
Get:1 http://kali.download/kali kali-rolling/main amd64 mitmproxy all 12.2.3-0kali2 [1,329 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 python3-flask all 3.1.3-4 [106 kB]
Fetched 1,435 kB in 9s (159 kB/s)
(Reading database ... 422168 files and directories currently installed.)
Preparing to unpack .../mitmproxy_12.2.3-0kali2_all.deb ...
Unpacking mitmproxy (12.2.3-0kali2) over (12.2.0-0kali1) ...
Preparing to unpack .../python3-flask_3.1.3-4_all.deb ...
Unpacking python3-flask (3.1.3-4) over (3.1.2-1) ...
Setting up python3-flask (3.1.3-4) ...
Setting up mitmproxy (12.2.3-0kali2) ...
Processing triggers for kali-menu (2025.4.3) ...
(kali@kali)~/network-rail-lab/captive-portal|
$ cd ~/network-rail-lab
(kali@kali)~/network-rail-lab|
$ nano app.py

```

```

kali@kali: ~/network-rail-lab/captive-portal
Session Actions Edit View Help
(kali@kali)~/network-rail-lab/captive-portal|
$ cat index.html
<!DOCTYPE html>
<html>
<head>
  <title>Station Public Wi-Fi</title>
  </head>
<body>
  <h1>Station Public Wi-Fi</h1>
  <p>Welcome to the Public Wi-Fi Portal</p>
  <p>Connect to the station Wi-Fi service.</p>
  <button>Connect to Wi-Fi</button>
  <br><br>
  <a href="login.html">Administrator Login</a>
</body>
</html>
(kali@kali)~/network-rail-lab/captive-portal|
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
127.0.0.1 - - [21/Aug/2025 23:22:36] "GET / HTTP/1.1" 200 -

```

```
(kali@kali)~/network-rail-lab
$ nano app.py

(kali@kali)~/network-rail-lab
$ python3 app.py
* Serving Flask app 'app'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on http://127.0.0.1:5000
Press CTRL+C to quit
127.0.0.1 - - [21/Aug/2026 23:29:38] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [21/Aug/2026 23:29:39] "GET /favicon.ico HTTP/1.1" 404 -
127.0.0.1 - - [21/Aug/2026 23:29:42] "GET /login HTTP/1.1" 200 -
127.0.0.1 - - [21/Aug/2026 23:29:56] "POST /login HTTP/1.1" 302 -
127.0.0.1 - - [21/Aug/2026 23:29:56] "GET /admin HTTP/1.1" 200 -
```